Stage 1: Reconnaissance

Before launching any attack, adversaries gather intelligence on their target. This falls into two categories: passive reconnaissance, i.e. browsing public websites, scraping LinkedIn, reading job postings, and using WHOIS lookups; and active reconnaissance, which involves directly probing systems through port scanning and banner grabbing. Social media is a goldmine for attackers, with employees often unknowingly revealing technology stacks, org structures, and internal processes. Defenders can limit exposure through regular external attack surface assessments, employee awareness training, and minimizing publicly visible technical detail.

Stage 2: Weaponization

With target intelligence in hand, attackers build or acquire their tools. This means pairing an exploit, a mechanism that takes advantage of a specific vulnerability, with a payload such as a Remote Access Trojan, ransomware, or keylogger. Common weapons include malicious Office documents embedded with macros, PDFs with JavaScript payloads, and zero-day exploits targeting unpatched software. This phase happens entirely off-network, making it invisible to defenders. Organizations counter it by consuming threat intelligence, tracking known attacker tooling through frameworks like MITRE ATT&CK, and hardening systems against commonly weaponized vulnerabilities.

Stage 3: Delivery

Delivery is the first moment the attack crosses into the target's environment, and the first real detection opportunity. Email remains the dominant vector: phishing and spear phishing campaigns are tailored using reconnaissance data to appear convincingly legitimate. Other delivery methods include drive-by downloads from compromised websites, watering hole attacks, physical USB drops, and supply chain compromises where malware is embedded in trusted software updates. Defending this phase requires layered email filtering, web proxies, endpoint protection, and ongoing user awareness training to help employees recognize and report suspicious communications before damage is done.

Stage 4: Exploitation

Exploitation is the moment the weapon fires, the attacker's code takes advantage of a vulnerability and begins executing inside the target environment. Targets include software flaws like buffer overflows and SQL injection, hardware-level vulnerabilities such as Spectre and Meltdown, and human weaknesses exploited through social engineering. Zero-day exploits, targeting vulnerabilities unknown to the vendor, provide a significant asymmetric advantage. Defenders reduce risk through rigorous patch management, application

whitelisting, least-privilege access controls, and network segmentation that limits the blast radius even when exploitation succeeds.

Stage 5: Installation

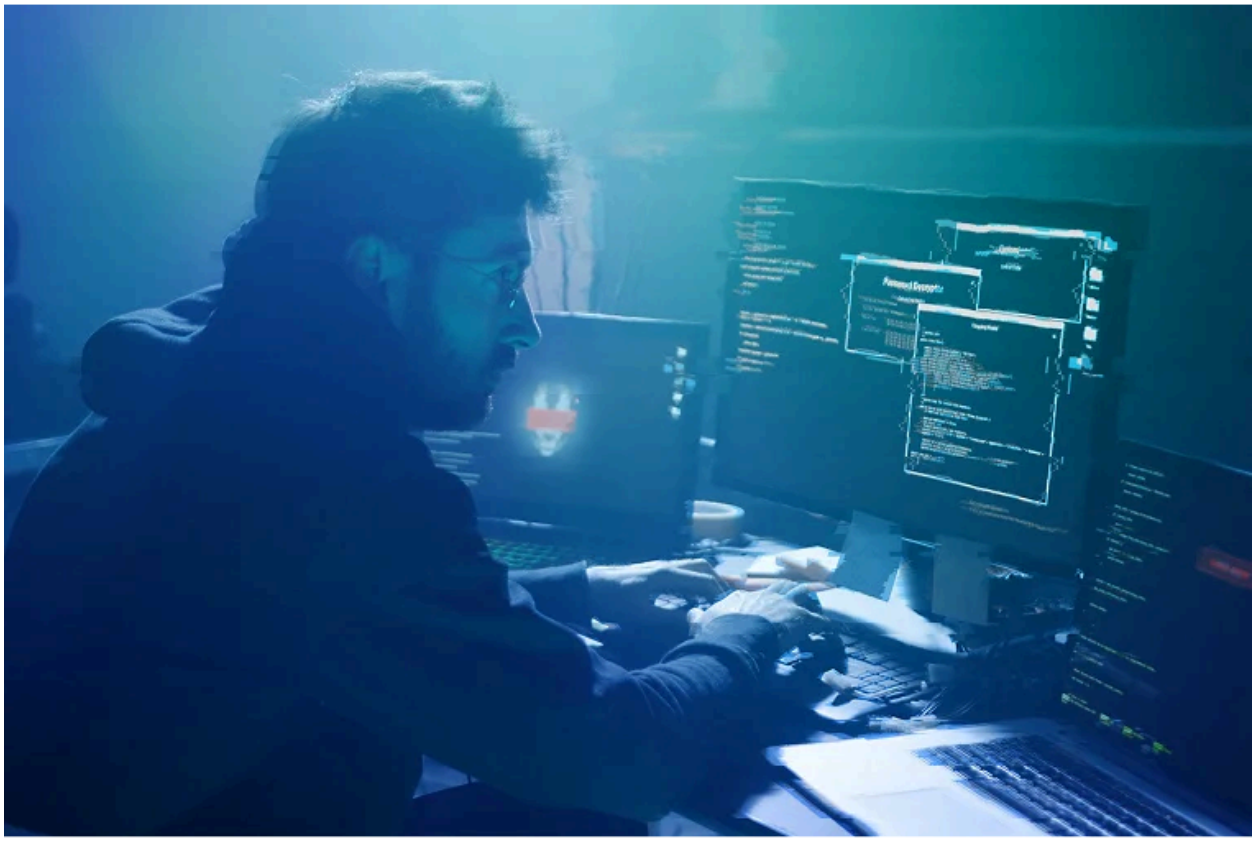
Exploitation gives access; installation makes it last. Attackers establish persistence so their foothold survives reboots and remediation attempts. Common mechanisms include Remote Access Trojans (RATs) disguised as legitimate processes, rootkits that hide at the kernel level, and web shells uploaded to compromised servers for browser-based command access. Attackers also achieve persistence through rogue user accounts, modified scheduled tasks, altered startup scripts, and Windows registry auto-run keys. Defenders should deploy endpoint detection and response (EDR) tools, monitor system integrity, and regularly audit scheduled tasks, startup items, and user accounts for unauthorized changes.

Stage 6: Command and Control (C2)

With persistence established, attackers need a communication channel to issue commands and receive data. Modern C2 infrastructure is sophisticated: Domain Generation Algorithms (DGAs) produce rotating domain names to evade blocking, while legitimate platforms like Slack, GitHub, and Google Drive are increasingly abused to blend malicious traffic with normal activity. Attackers favor HTTPS for encryption and DNS tunneling to move data through rarely-inspected protocols. Beacon intervals are randomized to defeat anomaly detection. Defenders counter C2 through network traffic analysis, DNS monitoring, TLS inspection, and threat intelligence feeds that flag known malicious infrastructure.

Stage 7: Actions on Objectives

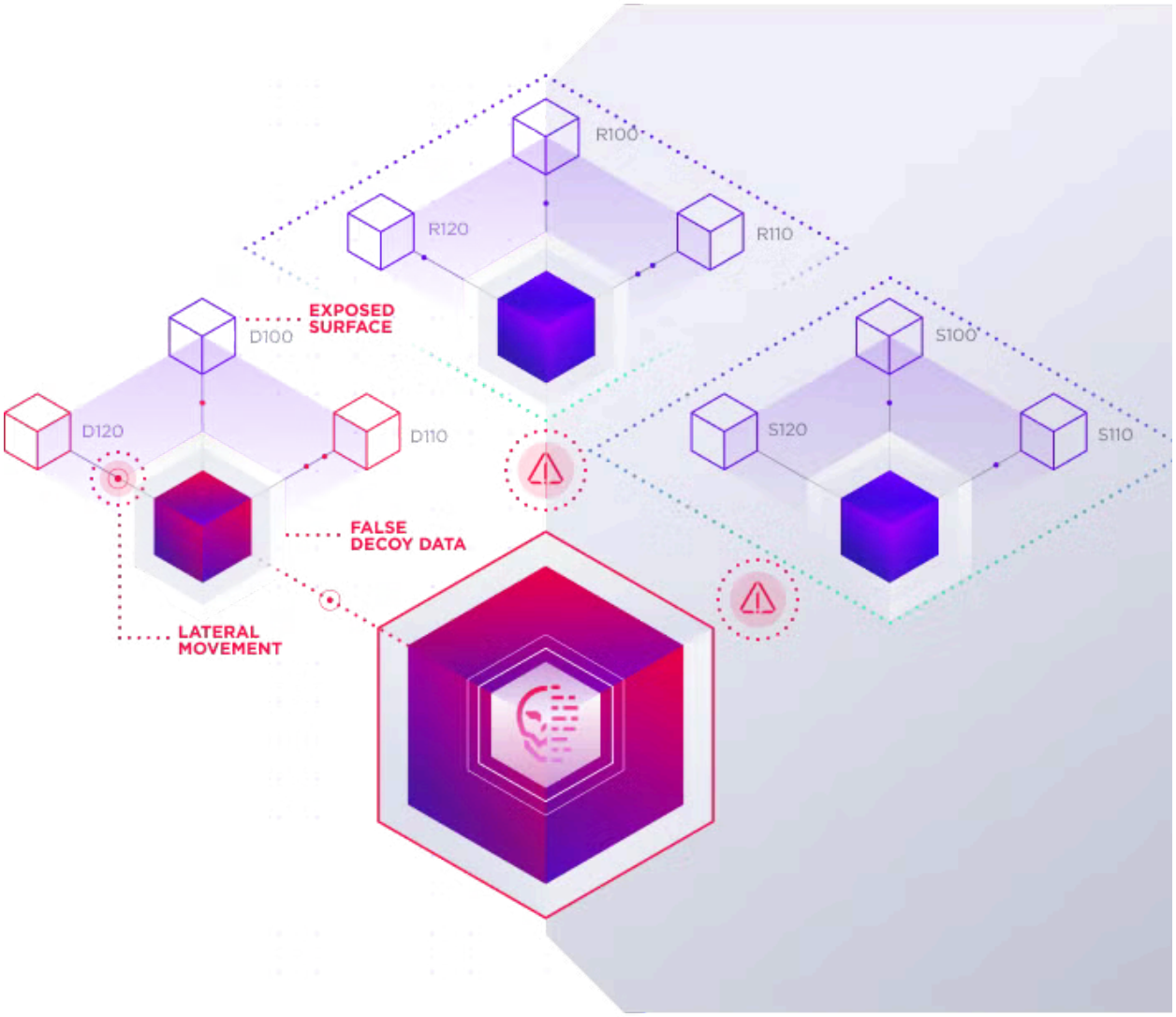
This is what the attacker came for. Objectives vary by motivation: espionage operations focus on data exfiltration, carefully staging and slowly moving sensitive files to avoid triggering data loss prevention tools. Ransomware operators disable backups, escalate to domain administrator, and often exfiltrate data before encrypting it, enabling double extortion. Destructive attacks deploy wiper malware to permanently destroy systems. In all cases, lateral movement is critical, with attackers pivoting across the network using techniques like Pass-the-Hash and Kerberoasting to reach high-value targets. Strong detection, segmentation, and incident response can stop attackers even at this late stage.



GIF: https://threatintelligencelab.com/cyber-attack-cycle/exploitation-phase/

87%

C2


R100
R120
R110
EXPOSED SURFACE
D100
D120
D110
S100
S120
S110
FALSE DECOY DATA
LATERAL MOVEMENT